TUGAS 3
Validasi, Error, dan Auth

A. KETENTUAN UMUM

1. Dikerjakan secara individu, melanjutkan project Tugas 2.
2. Validasi input memakai zod, dengan satu format error handling.
3. Autentikasi memakai JWT.
4. Wajib membedakan 401 (belum/tidak terautentikasi) dan 403 (sudah login, tidak punya akses).
5. Role: admin, owner, customer. Identitas user diambil dari token, bukan request body.
6. Dokumentasi API disajikan di `/docs` (Swagger/OpenAPI).

B. Peran & Akun Uji

Role	Hak Akses
admin	Semua endpoint
owner	Endpoint mengelola warung miliknya
customer	Menambah review
public (no role)	Public endpoint dan auth

C. Format Error

Contoh error kaya gini:

```
{
  "status": "fail",
  "message": "Validasi gagal",
  "errors": [
    { "field": "name", "message": "name minimal 3 karakter" },
    { "field": "password", "message": "password minimal 8 karakter" }
  ]
}
```

D. Skema Validasi per Endpoint

Endpoint	Sumber	Aturan Validasi
GET /stalls	query	- search: string, trim, maks 100, opsional. - category: string, trim, maks 50, opsional. - page: int, min 1, default 1. - limit: int, min 1, maks 100, default 10.
GET /stalls/:id	params	- id: int, lebih dari 0, wajib.
POST /stalls	body	- name: string, trim, 3..100, wajib. - category: string, trim, maks 50, opsional. - location string, maks 100, opsional. - description: maks 1000, opsional.
PUT /stalls/:id	params + body	- id: int, lebih dari 0, wajib. - body: versi parsial dari POST /stalls (semua opsional).
DELETE /stalls/:id	params	- id: int, lebih dari 0, wajib.
POST /stalls/:id/reviews	params + body	- id: int, lebih dari 0, wajib. - rating: int, 1..5, wajib. - comment: string, trim, maks 1000, opsional.
POST /auth/register	body	- name: string, trim, 3..100, wajib. - email: format email, trim, lowercase, maks 150, wajib. - password: 8..72, wajib.
POST /auth/login	body	- email: format email, trim, lowercase, wajib. - password: minimal 1, wajib.
GET /auth/me	header	tidak ada body/params.

E. Kewajiban Endpoint & Otorisasi

Endpoint	Akses
GET /stalls, GET /stalls/:id	publik
POST /auth/register, POST /auth/login	publik
GET /auth/me	login (semua role)
POST /stalls/:id/reviews	login (semua role)

Endpoint	Akses
POST /stalls	owner, admin
PUT /stalls/:id	owner (hanya miliknya), admin
DELETE /stalls/:id	admin

F. LAPORAN INDIVIDU

Setiap mahasiswa membuat **Laporan PDF** dengan format nama file: `NIM_Nama.pdf`

Isi Laporan:

1. Identitas
   - Nama
   - NIM
   - Kelas
   - URL Repository GitHub
2. Bukti Screenshot
   - Ketika validasi gagal, satu saja.
   - Bukti format error di output.
   - Prosedur register dan login.
   - Request tanpa token pada endpoint non-public, harus mengembalikan 401.
   - Owner mengubah warung milik orang lain, harus mengembalikan 403.
   - Role tidak memenuhi, harus mengembalikan 403.
   - Password harus di-hash dulu sebelum masuk database.

G. OUTPUT PENGUMPULAN

Mahasiswa mengumpulkan:

1. URL Repository GitHub (pastikan *visibility* set ke public)
2. File Laporan PDF dengan format `NIM_Nama.pdf`